



ASSESSMENT COVERSHEET

Attach this coversheet as the cover of your submission. All sections must be completed.

Section A: Submission Details

Programme : Bachelor Of Information Technology (Hons) In Computer System Security
Course Code & Name : IKB21403 - VULNERABILITY ANALYSIS
Course Lecturer(s) : Nor Adani Kamal Mohamad Nasir
Submission Title : LAB 4 (ADVANCED)
Deadline : Day 07 Month 06 Year 2026 Time 11.59pm
Penalties :

- 5% will be deducted per day to a maximum of four (4) working days, after which the submission will **not** be accepted.
- Plagiarised work is an Academic Offence in University Rules & Regulations and will be penalised accordingly.

Section B: Academic Integrity

Tick (✓) each box below if you agree:

- | | |
|-------------------------------------|--|
| ☒ | I have read and understood the UniKL's policy on Plagiarism in University Rules & Regulations. |
| ☒ | This submission is my own, unless indicated with proper referencing. |
| ☒ | This submission has not been previously submitted or published. |
| ☒ | This submission follows the requirements stated in the course. |

Section C: Submission Receipt

(must be filled in manually)

Office Receipt of Submission

Date & Time of Submission (stamp)	Student Name(s)	Student ID(s)
	1 HAZIQ DANIAL BIN NOR AZAN	52215225213

Student Receipt of Submission

This is your submission receipt, the only accepted evidence that you have submitted your work. After this is stamped by the appointed staff & filled in, cut along the dotted lines above & retain this for your record.

Date & Time of Submission (stamp)	Course Code	Submission Title	Student ID(s) & Signature(s)

Contents

1. Objective & Methodology	3
2. Risk Scoring Table — 5 Vulnerabilities	5
3. Individual Vulnerability Risk Analysis	6
3.1 VNC Server Weak Password — Risk Score: 125/125	6
3.2 Bind Shell Backdoor — Risk Score: 125/125	7
3.3 Ubuntu Linux EOL (8.04.x) — Risk Score: 60/125	8
3.4 SSL v2/v3 Detection — Risk Score: 18/125	8
3.5 Samba Badlock (CVE-2016-2118) — Risk Score: 18/125	9
4. Remediation Priority List	10
5. Key Lesson: Why Medium CVSS Can Outrank High CVSS	11
5.1 The Critical Comparison	11
5.2 Why Scenario A (Medium CVSS) is MORE Dangerous	12
5.3 Real-World Analogy	13

1. Objective & Methodology

Lab 4 teaches analysts to prioritise vulnerabilities based on RISK rather than CVSS severity score alone. A CVSS score measures the technical severity of a vulnerability in isolation, but real-world risk depends on three additional factors: how exploitable is it in THIS environment, what is the actual business impact, and how exposed is the vulnerable service to attackers.

The Core Problem with CVSS-Only Prioritisation:

- A CVSS 10.0 vulnerability on an internal database unreachable from the internet may be LESS urgent than a CVSS 5.0 vulnerability on an internet-facing login page with no authentication
- Blindly fixing vulnerabilities in CVSS order wastes budget and leaves high-exposure targets unprotected
- Real VA professionals use contextual risk scoring to create actionable remediation priority lists

Risk Scoring Framework Used:

Exploitability (E)	1-5 score: Is there a public exploit? Is it easy to use? Does it require special conditions?
Impact (I)	1-5 score: What is the worst-case outcome? RCE? Data loss? Privilege escalation? DoS?
Exposure (Ex)	1-5 score: Is the service internet-facing? Reachable from Kali? Internal only? Segmented?
Risk Score Formula	Risk Score = Exploitability x Impact x Exposure (max = 125)
Lab Context	DVWA/Metasploitable2 is reachable from Kali on the same Host-Only network — Exposure is elevated for ALL findings

Scoring Legend:

Score	Exploitability	Impact	Exposure	Weight
5/5	Public exploit, one-click RCE	Full system compromise / root	Internet-facing, no auth	Highest Risk
4/5	Known exploit, easy to use	RCE or full data access	Reachable from LAN/lab	High Risk
3/5	PoC exists, moderate skill	Privilege escalation / data leak	Restricted internal access	Medium Risk
2/5	No public exploit, hard to exploit	Partial data access / DoS	Requires MITM or auth	Low Risk
1/5	Theoretical only, very complex	Minimal / informational only	Fully segmented / isolated	Minimal Risk

2. Risk Scoring Table — 5 Vulnerabilities

The following table applies the risk scoring framework to all 5 vulnerabilities identified in Lab 1. Each vulnerability is scored on Exploitability, Impact, and Exposure, then a composite Risk Score is calculated.

Vulnerability	CVSS	E (1-5)	I (1-5)	Ex (1-5)	Risk Score	CVSS Rank	Risk Rank
VNC Server Weak Password (Port 5900)	10.0	5/5	5/5	5/5	125	#1	#1
Bind Shell Backdoor (Port 1524)	9.8	5/5	5/5	5/5	125	#2	#1
SSL v2/v3 Detection (Port 25 & 5432)	9.8	2/5	3/5	3/5	18	#2	#4
Ubuntu Linux EOL (OS-level)	10.0	3/5	5/5	4/5	60	#1	#3
Samba Badlock CVE-2016-2118 (Port 445)	7.5	2/5	3/5	3/5	18	#5	#4

Key:

E = Exploitability,

I = Impact,

Ex = Exposure.

Risk Score = E x I x Ex.

Higher = more urgent.

3. Individual Vulnerability Risk Analysis

3.1 VNC Server Weak Password — Risk Score: 125/125

#1	PRIORITY 1 — IMMEDIATE ACTION REQUIRED
----	--

Metric	Score	Justification
Exploitability	5/5	Public exploit trivial — just type 'password'. No tools needed. Nessus logged in automatically. Exploit in 10 seconds.
Impact	5/5	Full graphical desktop control as root. Can read/write/delete all files, install malware, use as pivot to other systems.
Exposure	5/5	Port 5900 open and reachable from Kali on same network. No firewall. No authentication barrier other than trivial password.

Justification:

VNC with the password 'password' is the most immediately dangerous finding because it combines perfect storm conditions: maximum exploitability (zero skill required), maximum impact (full root desktop access), and maximum exposure (directly reachable with no barriers). Any attacker who can ping the host can own it completely in under 30 seconds using just a VNC client application. CVSS 10.0 correctly reflects this, and the risk score of 125/125 confirms it is the absolute top priority. In a real engagement, this finding would trigger an emergency notification to the client within the hour.

3.2 Bind Shell Backdoor — Risk Score: 125/125

#1	PRIORITY 1 — IMMEDIATE ACTION REQUIRED (TIE)
----	--

Metric	Score	Justification
Exploitability	5/5	No exploit needed — just: nc 192.168.56.106 1524. Immediate root shell. Zero skill required. Simpler than VNC.
Impact	5/5	Root command-line shell — full system control. Can read /etc/shadow, install rootkits, pivot to other hosts.
Exposure	5/5	Port 1524 open and directly reachable. Confirmed by both Nessus and Nmap. No authentication whatsoever.

Justification:

The Bind Shell backdoor on port 1524 ties VNC for the highest risk score of 125/125. While VNC provides graphical access, the bind shell provides direct command-line root access which is arguably more dangerous for automated attacks and lateral movement. A single 'nc 192.168.56.106 1524' command gives an attacker a root shell — no password, no exploit code, no special tool required. The backdoor's presence also suggests the system may already be compromised, warranting a full forensic investigation in addition to immediate port blocking.

3.3 Ubuntu Linux EOL (8.04.x) — Risk Score: 60/125

#3	PRIORITY 3 — SHORT-TERM REMEDIATION
----	-------------------------------------

Metric	Score	Justification
Exploitability	3/5	Many known OS-level CVEs exist. Some have public exploits, but specific exploitation requires identifying the exact vulnerable component. Not trivially automated.
Impact	5/5	OS-level compromise = complete system takeover. Kernel exploits can bypass all other security controls. Highest possible impact if exploited.
Exposure	4/5	System is fully reachable on the local network. Multiple services expose attack surface. Not internet-facing in lab (hence 4 not 5).

Justification:

Ubuntu 8.04 EOL has a CVSS of 10.0 (same as VNC) but ranks #3 in risk priority because its exploitability score is lower. While the potential impact of an OS-level compromise is catastrophic, actually exploiting an EOL OS requires identifying a specific unpatched CVE and having a working exploit for it — unlike VNC and the bind shell which require literally zero exploitation skill. The risk is real and growing (every new CVE discovered can never be patched) but is less immediately urgent than the two pre-configured backdoors already present.

3.4 SSL v2/v3 Detection — Risk Score: 18/125

3.5 Samba Badlock (CVE-2016-2118) — Risk Score: 18/125

#4	PRIORITY 4 — PLANNED REMEDIATION (BOTH TIE)
----	---

Vuln	CVSS	E	I	Ex	Score	Key Reason for Lower Rank
SSL v2/v3	9.8 CRITICAL	2/5	3/5	3/5	18	Requires active MITM position on network + active session to intercept. Complex attack chain vs direct backdoor.
Samba Badlock	7.5 HIGH	2/5	3/5	3/5	18	Requires MITM + user to initiate SMB connection. Not direct exploitation. Lower real-world exploitability.

Joint Justification:

Despite SSL v2/v3 having a CVSS of 9.8 (Critical) — the SAME as the Bind Shell Backdoor — it ranks #4 in risk priority. Both SSL POODLE and Samba Badlock require the attacker to achieve a man-in-the-middle network position AND wait for a legitimate user to initiate a connection. In the isolated lab environment (Host-Only network with no other users), these conditions are difficult to meet. The CVSS score measures theoretical maximum severity, not practical exploitability in this specific context. These should be remediated in planned maintenance windows rather than as emergency fixes.

4. Remediation Priority List

Based on the risk scoring analysis, the following remediation priority list is recommended. Items are ordered by Risk Score, not CVSS:

Priority	Vulnerability	CVSS	Risk Score	Timeline	Remediation Action
P1	VNC Weak Password (Port 5900)	10.0	125	SAME DAY	Change VNC password to 16+ char complex password. Block port 5900 via firewall. Restrict access to trusted IPs only.
P1	Bind Shell Backdoor (Port 1524)	9.8	125	SAME DAY	Block port 1524 via firewall immediately. Kill backdoor process. Conduct forensic investigation. Consider system rebuild.
P3	Ubuntu EOL 8.04 (OS-level)	10.0	60	1-2 WEEKS	Plan OS upgrade to Ubuntu 22.04 LTS. Isolate system from production network until upgrade complete.
P4	SSL v2/v3 Detection (Port 25, 5432)	9.8	18	1 MONTH	Disable SSLv2 and SSLv3 on SMTP and PostgreSQL services. Enforce TLS 1.2 minimum. Schedule during maintenance window.
P4	Samba Badlock CVE-2016-2118 (Port 445)	7.5	18	1 MONTH	Upgrade Samba to v4.2.11+ or disable SMB if not needed. Implement network segmentation to limit MITM attack surface.

5. Key Lesson: Why Medium CVSS Can Outrank High CVSS

This is the most important concept in Lab 4. The following example demonstrates concretely why CVSS score alone is an insufficient prioritisation tool.

5.1 The Critical Comparison

	Scenario A: Medium CVSS	Scenario B: High CVSS
Vulnerability	DVWA Default Admin Login (admin/password)	Samba Badlock CVE-2016-2118
CVSS Score	5.3 MEDIUM	7.5 HIGH
Location	DVWA web app on port 80 — same as Metasploitable2	Port 445 — internal SMB service
Authentication Required	None — just browse to the page	Must have MITM position on network
User Action Needed	None — attacker initiates directly	Victim must initiate SMB connection
Public Exploit	No exploit needed — just type admin/password in browser	Requires specialised MITM tools (e.g. Ettercap)
Exposure	Internet-facing web interface — visible to anyone	Internal service — attacker must be on same network segment
Exploitability Score	5/5 — trivially exploitable	2/5 — requires complex preconditions
Impact Score	4/5 — full web app access, potential data exfil	3/5 — SAM database access if successful
Exposure Score	5/5 — directly reachable with no barriers	3/5 — internal, requires MITM
Risk Score	100/125 — HIGH REAL RISK	18/125 — LOW REAL RISK
Remediation Priority	P1 — Fix IMMEDIATELY	P4 — Planned maintenance

5.2 Why Scenario A (Medium CVSS) is MORE Dangerous

The DVWA default login (CVSS 5.3 Medium) is significantly more dangerous than Samba Badlock (CVSS 7.5 High) in this lab environment for three reasons:

- Zero preconditions vs multiple preconditions: Exploiting DVWA requires only a browser and typing 'admin'/password'. Exploiting Samba Badlock requires establishing a man-in-the-middle position AND waiting for a victim to initiate an SMB connection — two difficult-to-achieve conditions.
- Direct access vs indirect access: The DVWA web interface is immediately accessible to any network-connected attacker. Samba Badlock requires the attacker to be on the same network segment with MITM capability, which is a harder attack position to achieve in any network with basic security controls.
- Internet-facing vs internal-only: If Metasploitable2 were exposed to the internet (as many real DVWA deployments accidentally are), the default login would be discovered by automated scanners within hours. Samba on port 445 should never be internet-facing, and if it is, you have bigger problems.

The Lesson in One Sentence:

CVSS measures the worst-case technical severity in an ideal attack scenario. Risk = CVSS severity x Exploitability in YOUR environment x Exposure of YOUR service. A vulnerability that can be exploited by anyone with a browser in 10 seconds is MORE dangerous than a technically severe vulnerability that requires a PhD-level attack chain to execute.

5.3 Real-World Analogy

Think of it this way:

- A nuclear warhead in a locked underground bunker (High impact, Low exploitability, Low exposure) = LOWER immediate risk
- An unlocked front door to your house (Medium impact, High exploitability, High exposure) = HIGHER immediate risk

CVSS only measures the size of the warhead. Risk assessment measures whether someone can actually get to it and set it off. This is exactly what Lab 4 teaches — and exactly what separates a professional security analyst from someone who just runs a scanner and pastes the output.